UNIVERSITÉ FRANÇAISE KEYCE INFORMATIQUE

ET INTELLIGENCE ARTIFICIELLE

RAPPORT DE L'ATELIER DE CYBERSECURITE

BACHELOR 2

ATELIER 1

PRÉSENTATION TENUE DU 01 AU 14 Avril 2025

RÉDIGÉ ET PRÉSENTÉ PAR LES MEMBRES DU GROUPE 1

SOUS LA DIRECTION ACADÉMIQUE DE :

M. ESSOMBA

ANNEE ACADEMIQUE 2024/2025

INTRODUCTION

À l'ère du tout numérique, les systèmes d'information sont devenus les piliers essentiels des entreprises modernes, qu'il s'agisse de gestion, de communication ou de services aux clients. Cette dépendance technologique, bien qu'elle apporte performance et efficacité, expose aussi les organisations à des cybers menaces de plus en plus fréquentes, ciblées et sophistiquées. Dans ce contexte, la cyber sécurité n'est plus une option mais une nécessité vitale, notamment face à des attaques qui visent non seulement à perturber les services mais aussi à voler, altérer ou exploiter des données sensibles. Dans le cadre de cet atelier, deux scénarios réalistes de cyberattaques sont étudiés dans le but de développer une compréhension approfondie des mécanismes d'intrusion, des vulnérabilités exploitées et des réponses à apporter. Le premier scénario concerne la compromission du système de réservation d'un hôtel de luxe, entraînant une fuite massive de données personnelles et financières de ses clients. Le second scénario, plus critique encore, met en scène une attaque par ransomware ciblant les systèmes SCADA d'une entreprise de distribution d'énergie, paralysant l'ensemble de son réseau électrique. À travers l'analyse de ces deux cas, l'objectif est d'acquérir une vision globale du cycle de vie d'une cyberattaque, d'apprendre à identifier les failles techniques, humaines et organisationnelles, et de formuler des mesures de sécurité concrètes et adaptées. Il s'agit également d'être capable de proposer un plan d'action opérationnel et structuré, garantissant à la fois la protection des actifs numériques et la continuité des activités. Cet exercice, à la fois théorique et pratique, prépare les étudiants à intervenir de manière rigoureuse et efficace dans des situations de crise informatique réelle.

SCENARIO 1:

CYBERATTAQUE PAR RANSOMWARE CIBLANT UN SYSTEME SCADA DANS UNE ENTREPRISE DE DISTRIBUTION D'ELECTRICITE.

I. PRÉSENTATION DU SCÉNARIO DE CYBERATTAQUE

1. Contexte de l'entreprise ciblée

L'entreprise visée est un acteur majeur de la distribution d'énergie électrique au niveau national. Elle gère un réseau complexe d'infrastructures critiques, allant de la production à la distribution d'électricité, en passant par la régulation de la tension, la gestion de la charge, et le contrôle des flux. Pour garantir un suivi en temps réel et une automatisation efficace, l'entreprise s'appuie sur un système SCADA (Supervisory Control and Data Acquisition) intégré à son réseau industriel.

Le système SCADA est au cœur du pilotage opérationnel : il supervise les capteurs à distance, gère les alarmes, collecte des données industrielles, et envoie des commandes aux équipements. La disponibilité et l'intégrité de ce système sont donc vitales pour le bon fonctionnement de la distribution électrique. Toute perturbation pourrait entraîner des coupures massives, des dysfonctionnements dans les équipements, voire des incidents de sécurité physique.

2. Fonctionnement et vulnérabilité du système SCADA

Le système SCADA repose sur une infrastructure distribuée composée :

- de terminaux distants (RTU, PLC) pour interagir avec les équipements physiques,
- de serveurs centraux (serveur SCADA, base de données industrielle),
- de postes opérateurs pour la visualisation et le contrôle humain,
- d'un réseau interne souvent interconnecté à l'IT, voire exposé via des interfaces de gestion.

Historiquement conçus pour la performance et la disponibilité, ces systèmes n'intègrent pas de mécanismes de sécurité robustes**.** Les protocoles utilisés (Modbus, DNP3, IEC 60870) sont souvent anciens, non chiffrés, et sans authentification native. Ce manque de sécurisation structurelle fait du SCADA une cible privilégiée pour des acteurs malveillants, notamment les

groupes APT (Advanced Persistent Threat) et les cybercriminels intéressés par le sabotage ou la rançon.

3. Objectifs potentiels de l'attaquant

L'attaque vise à paralyser l'activité de supervision du réseau électrique, en chiffrant les données SCADA à l'aide d'un ransomware spécialement conçu pour les systèmes industriels. Le but est d'interrompre la chaîne de contrôle, perturber les opérations, et forcer l'entreprise à payer une rançon en échange d'une clé de déchiffrement.

Les conséquences attendues de cette attaque incluent :

- L'inaccessibilité des serveurs SCADA et des postes opérateurs ;
- L'arrêt partiel ou complet du réseau de distribution ;
- L'impossibilité de gérer les compteurs prépayés, entraînant la coupure pour les clients ;
- Une perte de contrôle sur la régulation électrique, avec des risques d'incident sur les équipements critiques ;
- Une perte de confiance des clients et des autorités, et une exposition juridique sévère.

4. Impact étier de l'attaque

Cette cyberattaque a un impact opérationnel, économique et stratégique majeur pour l'entreprise :

- Perte d'exploitation directe due à l'arrêt du système de supervision ;
- Dégradation de la qualité de service (coupures, retards de distribution, litiges clients) ;
- Amendes réglementaires en cas de non-respect de la norme NIS2 ou de protection des infrastructures critiques ;
- Image ternie auprès des partenaires et du grand public, ce qui affecte durablement la réputation ;
- Coûts élevés de réponse à incident, de restauration et de sécurisation post-attaque.

II. MODE OPÉRATOIRE DE L'ATTAQUANT (ALIGNÉ MITRE ATT&CK)

L'attaquant a suivi une progression classique en cyber sécurité offensive, en s'appuyant sur des tactiques connues dans le Framework MITRE ATT&CK, principalement issues du domaine Enterprise (Web et systèmes Linux/Windows)**.** Voici le déroulement détaillé de l'attaque :

- **Phase d'exploration**

L'attaquant commence par **scanner le site web de l'hôtel** via des outils comme Nmap, whatweb ou dirb, afin d'identifier les **ports ouverts**, les **technologies utilisées** (ex : PHP/MySQL), et les **points d'entrée** vulnérables.

- Il cible un formulaire de recherche de chambre.
- Il teste manuellement des payloads simples :

  CopierModifier
  ' OR '1'='1 --

- **Phase d'infiltration**

Après avoir confirmé la présence d'une injection SQL, il automatise l'exploitation avec sqlmap, qui lui permet **d'**extraire la structure de la base de données, puis de voler les données des clients**.**

bash
CopierModifier
sqlmap -u "https://hotel-luxe.com/reservation.php?id=12" --dump

- **Phase d'exécution**

L’attaquant téléverse un web shell PHP (ex : cmd.php) dans le serveur via une faille ou un upload non sécurisé, pour obtenir une interface d’exécution de commandes à distance**.**

4. Phase d’escalade de privilèges

Une fois sur le serveur, il utilise un outil comme Linux Exploit Suggester pour détecter une faille kernel non corrigée, lui permettant de passer root via un exploit local.

- **Phase de collecte et exfiltration**

Il regroupe les fichiers sensibles (exports SQL, fichiers .env, données client) dans une archive, et l’exfiltre vers un serveur distant via scp ou curl.

- **Phase de dissimulation**

Avant de quitter le système, il :

- Vide les journaux,
- Supprime ses outils,
- Modifie les dates d’accès (touch),
- Et laisse une backdoor persistante (ex : shell accessible via URL).

Tableau 1 : Corrélation de l’attaque avec MITRE ATT&CK

Phase de l’attaque	Action de l’attaquant	Technique MITRE ATT&CK associée
Reconnaissance	Scan du site, identification des vulnérabilités	T1595 – Active Scanning
Accès initial	Exploitation d’injection SQL sur un formulaire	T1190 – Exploit Public-Facing Application
Exécution	Télé versement de web shell, exécution de commandes PHP	T1059.003 – Command and Scripting Interpreter: PHP

Persistance	Déploiement de backdoor web, planification automatique	T1505.003 – Server Software Component
Privilege Escalation	Exploitation d'une faille locale pour devenir root	T1068 – Exploitation for Privilege Escalation
Exfiltration	Compression des données + transfert vers serveur distant	T1048 – Exfiltration Over Alternative Protocol
Defense Evasion	Suppression de logs, modification de métadonnées, nettoyage	T1070 – Indicator Removal on Host

III. ANALYSE DES VULNÉRABILITÉS EXPLOITÉES

Chaque technique utilisée par l'attaquant repose sur une ou plusieurs vulnérabilités spécifiques, souvent simples à corriger mais négligées. Ces failles sont classées ici selon leur nature : technique, humaine ou organisationnelle. Elles ont permis à l'attaquant de progresser dans le système avec une facilité déconcertante.

Tableau 2 : Vulnérabilités par technique MITRE ATT&CK

Technique MITRE ATT&CK (ID)	Vulnérabilité exploitée	Type de vulnérabilité	Description détaillée
T1595 – Active Scanning	Pas de filtrage IP ni de détection de scans	Technique	Le site n'implémente aucune mesure de détection basique (IDS/IPS, règles WAF) pour bloquer les scans réseau ou web.

T1190 – Exploit Public-Facing App	Injection SQL non filtrée sur formulaire public	Technique	Les entrées utilisateurs sont insérées directement dans les requêtes SQL sans protection (pas de requêtes préparées).
T1059.003 – Command and Scripting: PHP	Upload non sécurisé, validation absente	Technique	L'absence de contrôle sur les fichiers uploadés permet à l'attaquant d'envoyer un script malveillant PHP.
T1505.003 – Server Component	Application vulnérable aux modules malveillants	Technique / Organisationnelle	Des modules additionnels sont chargés sans vérification d'intégrité ni restriction d'extension.
T1068 – Privilege Escalation	OS obsolète, pas de correctifs, permissions mal gérées	Technique	Le serveur est sous Linux sans politique de mise à jour, avec des droits mal configurés (SUID/root sur des binaires).
T1048 – Exfiltration Alt. Protocol	Pas de proxy, pas de contrôle sur les connexions sortantes	Technique / Organisationnelle	Le pare-feu laisse passer des connexions vers des IP inconnues, sans journalisation ni alerte.
T1070 – Indicator Removal on Host	Logs système accessibles en écriture, aucune surveillance active	Organisationnelle	L'attaquant peut supprimer ses traces sans être détecté, les journaux ne sont ni centralisés ni protégés.

Ces vulnérabilités démontrent une absence de politique de sécurité cohérente :

- Pas de développement sécurisé (OWASP),
- Pas de gestion des privilèges,
- Pas de supervision des actions critiques,
- Et une configuration du serveur très permissive.

Cela souligne l'urgence de mettre en œuvre des contre-mesures précises et adaptées, que nous allons définir dans la prochaine section, en s'appuyant sur le Framework MITRE D3FEND.

IV. RECOMMANDATIONS DE SÉCURITÉ (ALIGNÉES MITRE D3FEND)

Pour chaque technique exploitée par l'attaquant, il existe des **contre-mesures précises** permettant de **prévenir l'attaque, détecter son exécution, ou limiter son impact**. Le Framework MITRE D3FEND fournit une base solide pour construire une **stratégie de défense complète**, à la fois technique et organisationnelle.

Tableau 3: Recommandations alignées sur MITRE D3FEND

Technique MITRE ATT&CK exploitée	Recommandation de sécurité	Technique MITRE D3FEND associée (ID + nom)
T1595 – Active Scanning	Bloquer les scans via un WAF et activer des règles IDS/IPS	D3-NSE – Network Segmentation

T1190 – Exploit Public-Facing App	Implémenter des requêtes préparées et filtrer les entrées utilisateurs	D3-WAF – Web Application Firewall
T1059.003 – Command & Scripting: PHP	Restreindre les types de fichiers autorisés à l'upload, activer antivirus/antimalware	D3-EFA – Executable File Analysis
T1505.003 – Server Software Component	Vérifier les composants serveurs installés, bloquer ceux non signés / non autorisés	D3-EAL – Execution Allowlisting
T1068 – Exploitation Privilege Escal.	Mettre à jour l'OS et durcir les permissions fichiers sensibles	D3-UVS – Vulnerability Scanning
T1048 – Exfiltration Alt. Protocol	Restreindre les connexions sortantes, journaliser tous les transferts	D3-NCB – Network Connection Behavior Analysis
T1070 – Indicator Removal on Host	Centraliser et verrouiller les logs système, activer une supervision temps réel	D3-LM – Logging and Monitoring

Ce plan de défense est réaliste, modulaire, et applicable progressivement. Il permet à l'entreprise de :

- Bloquer les intrusions dès la couche applicative,
- Renforcer la sécurité du serveur (durcissement, patching),
- Réduire les privilèges inutiles,
- Et préparer une réaction rapide en cas d'incident (logs, alertes, traçabilité).

V. PLAN D'ACTION DE SÉCURITÉ

Ce plan permet de piloter l'application des mesures de sécurité, en s'appuyant sur les ressources internes de l'hôtel (équipe IT, prestataire web, direction) tout en respectant les contraintes budgétaires et organisationnelles. Il favorise une approche structurée de la cyber sécurité, en mode projet.

Tableau 4 : Plan d'action opérationnel

Description de l'action	Responsable désigné	Délai de mise en œuvre
Mettre en place un WAF avec filtrage d'injection SQL	Prestataire web	15 jours
Implémenter des requêtes préparées dans tous les formulaires	Développeur back-end	10 jours
Restreindre l'upload de fichiers aux formats sécurisés (.jpg, .pdf), bloquer le PHP	Équipe technique web	7 jours
Mettre à jour le système d'exploitation du serveur	Responsable serveur	5 jours
Installer un antivirus serveur + scanner de fichiers téléversés	Admin système / Sécurité	10 jours
Mettre en place des sauvegardes automatiques + hors site chiffrées	Responsable IT	15 jours
Journaliser tous les accès et centraliser les logs sur un serveur sécurisé	Admin système	12 jours
Restreindre les connexions sortantes aux domaines approuvés	Équipe réseau	10 jours

Former le personnel à la sécurité web et au social engineering	Direction + consultant cyber	20 jours
Rédiger une politique de réponse aux incidents (PRI) spécifique au site web	RSSI ou DSI	15 jours

VI. CONCLUSION ET SYNTHÈSE STRATÉGIQUE

L'attaque sur le système de réservation de l'hôtel de luxe démontre à quel point une **faille simple,** comme une injection SQL, peut avoir des conséquences critiques **s**i elle s'inscrit dans un enchaînement d'actions bien coordonnées. En combinant des outils standards, des techniques connues, et l'exploitation de vulnérabilités techniques et organisationnelles, l'attaquant a pu :

- Extraire des données clients sensibles,
- Prendre le contrôle du serveur,
- Et maintenir un accès persistant sans être détecté.

Ce rapport a permis :

- d'identifier les phases clés de l'attaque selon le Framework MITRE ATT&CK,
- de mettre en évidence les vulnérabilités associées,
- et de proposer des contre-mesures efficaces alignées sur MITRE D3FEND.

Il est désormais impératif que l'organisation :

- Adopte une posture de sécurité proactive**,**
- Implique toutes ses équipes dans la sécurisation du SI,
- Et établisse une culture cyber sécurité durable via des audits, de la formation et des plans de prévention/réaction.

Tableau 5 : Récapitulatif global de l'attaque et des contre-mesures

Phase de l'attaque	Action de l'attaquant	Technique MITRE ATT&CK	Vulnérabilité exploitée	Recommandation de sécurité	Technique MITRE D3FEND associée
Reconnaissance	Scan du site web	T1595 – Active Scanning	Pas de filtrage réseau ni WAF	Bloquer les scans avec WAF/IPS	D3-NSE – Network Segmentation
Accès initial	Exploitation d'injection SQL	T1190 – Exploit Public-Facing App	Absence de requêtes préparées, filtrage inexistant	Implémenter des requêtes préparées	D3-WAF – Web Application Firewall
Exécution	Télé versement et exécution d'un web shell PHP	T1059.003 – PHP Script Execution	Upload libre, absence de vérification MIME	Restreindre les formats uploadés	D3-EFA – Executable File Analysis
Persistance	Ajout d'un backdoor pour retour discret	T1505.003 – Server Component	Composants serveur non validés	Contrôle strict des modules installés	D3-EAL – Execution Allowlisting
Privilege Escalation	Utilisation d'un exploit local pour devenir root	T1068 – Privilege Escalation	OS non mis à jour, droits mal configurés	Mettre à jour le serveur, durcir la config	D3-UVS – Vulnerability Scanning
Exfiltration	Envoi d'une archive de données volées vers serveur	T1048 – Alt. Protocol Exfiltration	Absence de contrôle des connexions sortantes	Journaliser les transferts, restreindre le net	D3-NCB – Network Connection Behavior

Effacement des traces	Suppression des logs, modification des fichiers	T1070 – Indicator Removal on Host	Logs locaux non protégés, aucune supervision	Centraliser et verrouiller les journaux	D3-LM – Logging and Monitoring

SCENARIO 2 :

CYBERATTAQUE PAR RANSOMWARE CIBLANT UN SYSTEME SCADA DANS UNE ENTREPRISE DE DISTRIBUTION D'ELECTRICITE.

I. PRÉSENTATION DU SCÉNARIO DE CYBERATTAQUE

1. Contexte de l'entreprise ciblée

L'entreprise visée est un acteur majeur de la distribution d'énergie électrique au niveau national. Elle gère un réseau complexe d'infrastructures critiques, allant de la production à la distribution d'électricité, en passant par la régulation de la tension, la gestion de la charge, et le contrôle des flux. Pour garantir un suivi en temps réel et une automatisation efficace, l'entreprise s'appuie sur un système SCADA (Supervisory Control and Data Acquisition) intégré à son réseau industriel.

Le système SCADA est au cœur du pilotage opérationnel : il supervise les capteurs à distance, gère les alarmes, collecte des données industrielles, et envoie des commandes aux équipements. La disponibilité et l'intégrité de ce système sont donc vitales pour le bon fonctionnement de la distribution électrique. Toute perturbation pourrait entraîner des coupures massives, des dysfonctionnements dans les équipements, voire des incidents de sécurité physique.

2. Fonctionnement et vulnérabilité du système SCADA

Le système SCADA repose sur une infrastructure distribuée composée :

- de terminaux distants (RTU, PLC) pour interagir avec les équipements physiques,
- de serveurs centraux (serveur SCADA, base de données industrielle),
- de postes opérateurs pour la visualisation et le contrôle humain,
- d'un réseau interne souvent interconnecté à l'IT, voire exposé via des interfaces de gestion.

Historiquement conçus pour la performance et la disponibilité, ces systèmes n'intègrent pas de mécanismes de sécurité robustes. Les protocoles utilisés (Modbus, DNP3, IEC 60870) sont souvent anciens, non chiffrés, et sans authentification native. Ce manque de sécurisation structurelle fait du SCADA une cible privilégiée pour des acteurs malveillants, notamment les

groupes APT (Advanced Persistent Threat) et les cybercriminels intéressés par le sabotage ou la rançon.

3. Objectifs potentiels de l'attaquant

L'attaque vise à paralyser l'activité de supervision du réseau électrique, en chiffrant les données SCADA à l'aide d'un ransomware spécialement conçu pour les systèmes industriels. Le but est d'interrompre la chaîne de contrôle, perturber les opérations, et forcer l'entreprise à payer une rançon en échange d'une clé de déchiffrement.

Les conséquences attendues de cette attaque incluent :

- L'inaccessibilité des serveurs SCADA et des postes opérateurs ;
- L'arrêt partiel ou complet du réseau de distribution ;
- L'impossibilité de gérer les compteurs prépayés, entraînant la coupure pour les clients ;
- Une perte de contrôle sur la régulation électrique, avec des risques d'incident sur les équipements critiques ;
- Une perte de confiance des clients et des autorités, et une exposition juridique sévère.

4. Impact métier de l'attaque

Cette cyberattaque a un impact opérationnel, économique et stratégique majeur pour l'entreprise :

- Perte d'exploitation directe due à l'arrêt du système de supervision ;
- Dégradation de la qualité de service (coupures, retards de distribution, litiges clients) ;
- Amendes réglementaires en cas de non-respect de la norme NIS2 ou de protection des infrastructures critiques ;
- Image ternie auprès des partenaires et du grand public, ce qui affecte durablement la réputation ;
- Coûts élevés de réponse à incident, de restauration et de sécurisation post-attaque.

II. ANALYSE DU MODE OPÉRATOIRE DE L'ATTAQUANT

L'attaque contre le réseau SCADA de l'entreprise de distribution électrique s'est déroulée en plusieurs phases successives, chacune correspondant à une tactique MITRE ATT&CK bien identifiée. Ces étapes révèlent une attaque ciblée, structurée, et techniquement avancée, menée par un acteur disposant de connaissances en systèmes industriels.

- Phase 1 : Reconnaissance

L'attaquant démarre par une reconnaissance externe passive, collectant des informations sur l'entreprise à partir de ses publications, domaines, IP publiques, interfaces web exposées, etc. Ensuite, via un phishing, il infiltre le réseau interne et effectue une reconnaissance réseau interne pour identifier les machines, ports ouverts, services, et systèmes SCADA actifs.

- Outils possibles : Shodan, Nmap, Advanced IP Scanner, Wireshark.

- Phase 2 : Accès initial

L'attaquant envoie un email d'hameçonnage ciblé (spear phishing) à un technicien du département IT, avec une pièce jointe malveillante. Le fichier (Word, Excel) contient une macro VBScript ou un exécutable déguisé (.scr, .exe) permettant de prendre pied dans le réseau une fois ouvert.

- Payload utilisé : Trojan d'accès à distance (RAT), dropper, loader.

- Phase 3 : Exécuton

La charge utile est exécutée sur la machine compromise, souvent via macro Office ou script PowerShell automatisé. L'attaquant ouvre une session avec un C2 (command and control) distant pour commencer le déploiement du ransomware.

- Phase 4 : Persistance & Élévation de privilèges

L’attaquant établit la persistance via des tâches planifiées (schtasks), des clefs de registre Windows (HKCU\Software\Microsoft\Windows\CurrentVersion\Run) ou des services système.
Il exploite ensuite une vulnérabilité locale non corrigée pour élever ses privilèges au niveau administrateur sur plusieurs postes.

- Phase 5 : Mouvement latéral

Une fois admin sur une machine, l’attaquant se déplace latéralement vers les serveurs SCADA, en accédant aux partages réseau, en réutilisant les identifiants admin, ou en exploitant des failles connues (ex : EternalBlue - MS17-010).

- Phase 6 : Impact – Déploiement du ransomware

Le ransomware est lancé en masse sur :

- les serveurs SCADA,
- les bases de données,
- les systèmes de gestion des compteurs prépayés.

Il chiffre les fichiers critiques et affiche une demande de rançon avec menace de suppression des données si aucun paiement n’est effectué sous 72h.

Tableau 1 : Corrélation des phases de l’attaque avec MITRE ATT&CK

	Action de l’attaquant	**Technique MITRE ATT&CK (ID + nom)**
Reconnaissance	Collecte d'infos sur l'infrastructure, scan réseau interne	T1595 – Active Scanning (Enterprise) T0887 – Network Sniffing (ICS)
Accès initial	Phishing ciblé avec pièce jointe malveillante	T1566.001 – Spearphishing Attachment (Enterprise)

Exécution	Ouverture du fichier, exécution de macro ou script malveillant	T1059.001 – PowerShell / T1203 – Exploitation client
Persistance	Ajout de tâche planifiée, modification du registre Windows	T1053 – Scheduled Task / Job (Enterprise) T1547 – Boot/Logon Auto Start
Élévation de privilèges	Exploitation locale pour devenir administrateur	T1068 – Exploitation for Privilege Escalation
Mouvement latéral	Accès aux partages réseau, rebond vers serveurs SCADA	T1021.002 – SMB/Windows Admin Shares
Impact final	Déploiement d'un ransomware, chiffrement des fichiers critiques SCADA	T1486 – Data Encrypted for Impact

L'analyse du mode opératoire de l'attaquant à travers le prisme du Framework MITRE ATT&CK met en évidence une attaque structurée, progressive et ciblée, exploitant des techniques connues mais puissantes.

Chaque étape repose sur une faille préexistante du système d'information :

- Une configuration trop permissive du réseau,
- Une sécurité trop faible sur les postes utilisateurs,
- L'absence de segmentation entre IT et OT (SCADA),
- Et un manque de supervision de la sécurité opérationnelle.

Le succès de l'attaque ne réside pas dans la complexité des outils utilisés, mais plutôt dans la multiplication de petites négligences qui, combinées, ont permis à l'attaquant de progresser silencieusement jusqu'à atteindre les systèmes industriels critiques.

Il est donc crucial d'identifier précisément les vulnérabilités réelles derrière chaque technique, pour ensuite proposer des contre-mesures ciblées. C'est l'objectif de la prochaine section.

III. ANALYSE DES VULNÉRABILITÉS EXPLOITÉES

L'analyse des techniques MITRE ATT&CK précédemment identifiées met en lumière des vulnérabilités spécifiques, réparties en trois catégories principales : techniques, humaines et organisationnelles. Ces failles sont les points d'entrée réels de l'attaque et démontrent à quel point la sécurité d'un système repose sur un équilibre fragile entre les moyens techniques, les comportements des utilisateurs et la gouvernance du cyber sécurité.

Tableau 2 : Vulnérabilités exploitées par technique MITRE ATT&CK

Technique MITRE ATT&CK (ID)	Vulnérabilité identifiée	Type de vulnérabilité	Description détaillée
T1595 – Active Scanning	Absence de segmentation réseau, interfaces SCADA accessibles	Technique / Organisationnelle	Le réseau de supervision n'est pas isolé du réseau bureautique, ce qui permet le scan direct de systèmes critiques.
T1566.001 – Spearphishing Attachment	Manque de sensibilisation à l'ingénierie sociale	Humaine	Les employés ne sont pas formés aux techniques de phishing ciblé, et aucune simulation de phishing n'est réalisée.
T1059.001 – PowerShell	Politiques de restriction de script absentes ou non appliquées	Technique	PowerShell est autorisé sans restriction, sans journalisation renforcée, facilitant l'exécution non détectée de scripts.

T1053 – Scheduled Task / Job	Absence de surveillance des tâches planifiées	Organisationnelle / Technique	Les modifications planifiées ne sont pas auditées ni surveillées en temps réel.
T1068 – Privilege Escalation via Exploit	Systèmes obsolètes avec failles non corrigées	Technique	Des vulnérabilités locales connues sont présentes faute de mise à jour du système d'exploitation.
T1021.002 – SMB/Windows Admin Shares	Mots de passe faibles / réutilisation des identifiants	Humaine / Technique	Les mêmes identifiants sont utilisés sur plusieurs machines, sans politique de complexité ni MFA.
T1486 – Data Encrypted for Impact	Absence de sauvegarde hors ligne et de stratégie de restauration rapide	Organisationnelle	Aucune copie des données SCADA n'est disponible hors ligne, rendant la récupération impossible sans paiement.

Ce tableau met en évidence que chaque technique MITRE ATT&CK repose sur une faiblesse très concrète, souvent évitable. Le manque de segmentation réseau, l'absence de mise à jour des systèmes, et l'inexistence d'une culture de cyber sécurité au sein du personnel opérationnel sont des facteurs aggravants majeurs.

La défense efficace ne consiste pas à bloquer une technique individuellement, mais à rompre la chaîne de progression de l'attaquant dès les premiers signaux faibles.

IV. RECOMMANDATIONS DE SÉCURITÉ (ALIGNÉES MITRE D3FEND)

Chaque technique offensive utilisée par l'attaquant peut être contrée par une ou plusieurs techniques défensives référencées dans le Framework MITRE D3FEND. Ces mesures

s'inscrivent dans une démarche de cyber sécurité défensive structurée et proactive, à déployer selon le modèle détecter – bloquer – réagir – récupérer.

Tableau 3 : Recommandations alignées sur MITRE D3FEND

Technique MITRE ATT&CK utilisée	**Recommandation de sécurité**	**Technique MITRE D3FEND (ID + nom)**
T1595 – Active Scanning	Segmenter les réseaux IT et OT, cloisonner les flux SCADA	D3-NSE – Network Segmentation
T1566.001 – Spearphishing Attachment	Déployer des filtres anti-spam, DNS filtering, formation utilisateurs	D3-EF – Email Filtering
T1059.001 – PowerShell	Restreindre PowerShell, activer la journalisation avancée	D3-EAL – Execution Allowlisting
T1053 – Scheduled Task / Job	Surveiller les tâches planifiées, alerter sur modifications non légitimes	D3-LM – Logging and Monitoring
T1068 – Privilege Escalation	Maintenir les systèmes à jour, surveiller les comportements anormaux	D3-UVS – Vulnerability Scanning

T1021.002 – Admin Shares / Lateral Move	Activer MFA, changer régulièrement les mots de passe	D3-UVS – Vulnerability Scanning
T1486 – Data Encrypted for Impact	Mettre en place une stratégie de sauvegarde hors ligne régulière	D3-BR – Backup and Recovery

Le Framework MITRE D3FEND permet de traduire chaque action offensive en une réponse défensive claire. Il ne s'agit pas uniquement de bloquer les attaques, mais de :

- Limiter leur impact par la résilience (sauvegarde),
- Retarder leur progression par le cloisonnement (segmentation),
- Réduire leur fréquence par la prévention (filtrage, formation),
- Et réagir efficacement par la détection (logs, monitoring).

La mise en place de ces recommandations ne doit pas être vue comme un coût, mais comme un investissement stratégique dans la continuité d'activité de l'entreprise

V. PLAN D'ACTION DE SÉCURITÉ

Ce plan d'action est conçu pour **structurer et piloter la mise en œuvre des contre-mesures** nécessaires à la protection du système SCADA de l'entreprise. Chaque action est priorisée en fonction de sa criticité et associée à une **équipe ou fonction responsable**, ainsi qu'à un **délai de réalisation** réaliste mais ferme.

Tableau 4 : Plan d'action opérationnel

Description de l'action	Responsable	Délai de mise en œuvre

Segmenter les réseaux IT/OT pour isoler les systèmes SCADA	Équipe réseau & sécurité	30 jours
Déployer un WAF et surveiller les points d'accès web critiques	Équipe infrastructure	45 jours
Activer et renforcer les logs sur PowerShell, services SCADA et postes utilisateurs	Équipe systèmes	20 jours
Mettre à jour les OS et logiciels industriels critiques avec les derniers correctifs	Équipe technique SCADA	15 jours
Mettre en place un système de sauvegarde SCADA hors ligne, testé mensuellement	Responsable PRA/PCA	30 jours
Déployer une solution de filtrage des emails (antispam + sandbox de pièce jointe)	Équipe sécurité	10 jours
Former le personnel aux risques de phishing ciblé (campagne de sensibilisation)	RH + Sécurité	15 jours
Réviser la politique des mots de passe (complexité, rotation, MFA sur accès sensibles)	Équipe sécurité	10 jours
Implémenter un système de détection d'intrusion sur le réseau SCADA	Consultant cyber sécurité + IT/OT	45 jours
Rédiger un plan de réponse aux incidents spécifique aux attaqu es SCADA	RSSI + DSI + Direction générale	20 jours

VI. CONCLUSION ET RECOMMANDATIONS STRATÉGIQUES

Cette cyberattaque, qui a visé le système SCADA d'une entreprise de distribution d'électricité via un ransomware sophistiqué, a révélé la **fragilité d'une infrastructure critique** face à des menaces ciblées. En combinant **ingénierie sociale, déplacement latéral, et chiffrement de données industrielles**, l'attaquant a su exploiter **des vulnérabilités multiples et souvent négligées**, tant sur les plans techniques qu'organisationnels.

➢ Leçons à retenir

- Une attaque bien structurée peut **progresser sans obstacle** si les fondamentaux de la sécurité ne sont pas respectés (segmentation, correctifs, supervision).
- La **frontière entre le réseau IT et OT** n'est plus suffisante sans **contrôles actifs, audits réguliers et cloisonnement rigoureux**.
- Le **facteur humain** reste un maillon faible majeur : un simple clic peut compromettre toute une infrastructure.

➢ Recommandations stratégiques

Pour renforcer durablement la cyber sécurité de l'entreprise, il est indispensable de :

1. **Structurer la gouvernance de sécurité** autour d'un RSSI, d'un comité cyber sécurité et de procédures écrites (PRA, PRI, charte SI).
2. **Institutionnaliser la formation continue** de tous les employés, en particulier ceux ayant accès à des systèmes sensibles.
3. **Investir dans des solutions techniques robustes** (SIEM, EDR, segmentation, sauvegarde hors ligne) et les maintenir dans le temps.
4. **Mettre en place une culture de cyber sécurité proactive**, avec des audits réguliers, des tests d'intrusion et des simulations d'incident.
5. **S'aligner sur les référentiels reconnus** : MITRE ATT&CK/D3FEND, NIST, ISO 27001, RGPD, NIS2.

Tableau 5 : Tableau récapitulatif global de l'attaque et des contre-mesures

Phase de l'attaque	Action de l'attaquant	Technique MITRE ATT&CK	Vulnérabilité exploitée	Recommandation MITRE D3FEND	Technique D3FEND associée
Reconnaissance	Scan réseau, découverte des équipements SCADA	T1595 – Active Scanning	Pas de segmentation, SCADA accessible	Séparer IT/OT, cloisonner les flux	D3-NSE – Network Segmentation
Accès initial	Phishing avec pièce jointe malveillante	T1566.001 – Spearphishing Attachment	Absence de formation, absence d'antispam renforcé	Filtrage emails, formation utilisateurs	D3-EF – Email Filtering
Exécution	Lancement de script PowerShell	T1059.001 – PowerShell	Scripts non restreints, pas de journalisation	Restrictions sur PowerShell	D3-EAL – Execution Allowlisting
Persistance	Tâche planifiée, exécution au démarrage	T1053 – Scheduled Task	Absence de contrôle sur les tâches système	Monitoring des jobs, alertes	D3-LM – Logging & Monitoring
Privilege Escalation	Exploitation d'une faille système	T1068 – Privilege Escalation	OS non mis à jour, vulnérabilités connues	Patch management régulier	D3-UVS – Vulnerability Scanning

Mouvement latéral	Accès via partages admin, rebond vers SCADA	T1021.002 – SMB Admin Shares	Réutilisation de mots de passe, MFA absent	Rotation mots de passe, MFA	D3-CH – Credential Hardening
Impact (Final)	Chiffrement des données SCADA	T1486 – Data Encrypted for Impact	Absence de sauvegardes hors ligne	Sauvegarde isolée, test de restauration	D3-BR – Backup and Recovery

CONCLUSION GENERALE

Cet atelier de cyber sécurité nous a permis d'explorer de manière concrète et approfondie deux scénarios réalistes de cyberattaque, en appliquant une démarche d'analyse professionnelle fondée sur les référentiels MITRE ATT&CK (offensif) et MITRE D3FEND (défensif).

Dans le Scénario 1, nous avons étudié la compromission d'un système de réservation en ligne d'un hôtel de luxe. Cette attaque reposait sur des failles web classiques, exploitées pour infiltrer, escalader les privilèges, et exfiltrer des données sensibles de clients VIP.

Dans le Scénario 2, nous avons analysé une attaque par ransomware visant un réseau SCADA d'une entreprise de distribution d'électricité. Cette attaque était plus sophistiquée, ciblant une infrastructure critique avec pour objectif de paralyser les opérations industrielles et obtenir une rançon.

Au travers de ces deux scénarios, nous avons appris à :

- Cartographier les techniques d'attaque selon MITRE ATT&CK, en comprenant les tactiques utilisées à chaque phase (reconnaissance, exécution, exfiltration, etc.),
- Identifier les vulnérabilités réelles exploitées dans l'environnement technique, humain et organisationnel,

- Formuler des recommandations ciblées et alignées sur les techniques de défense MITRE D3FEND,
- Élaborer un plan d’action structuré, avec des actions, des responsables et des délais,
- Et enfin, proposer une vision stratégique de la cyber sécurité, alliant prévention, détection, réponse et résilience.

Cet atelier nous a démontré que la cyber sécurité ne se limite pas à la technique. Elle repose sur une approche globale, incluant la gouvernance, la formation humaine, la vigilance constante, et une capacité d’adaptation rapide face à des menaces évolutives.

Nous repartons de cet atelier avec une compréhension renforcée des enjeux cyber, et les outils méthodologiques pour contribuer activement à la protection des systèmes d'information, dans tout type d’organisation.